

the process easier and more effective.

- **Automate everything:** Automate tool execution, results analysis, and security gates in the CI/CD pipeline to shorten development cycles and reduce errors caused by manual processes.
- **Integrate with existing tools:** Integrate open source tools with existing development and security tools to improve collaboration and streamline workflows.
- **Use APIs and plugins:** Utilise APIs and plugins to integrate tools with the CI/CD pipeline and automate the entire software development process.
- **Configure and fine-tune tools:** Set up tool configurations, rules, and policies to reduce false positives and improve accuracy, ensuring maximum effectiveness.
- **Establish security gates:** Define security gates in the CI/CD pipeline to block or alert on security issues and prevent security breaches.
- **Monitor and respond:** Set up monitoring and logging to detect security incidents and establish incident response processes, ensuring that potential threats are addressed quickly and effectively.
- **Train and educate teams:** Provide training and resources for development and security teams on DevSecOps practices and tool usage, ensuring that everyone is on the same page and working towards the same goals.
- **Continuously improve:** Regularly review and update security objectives and tools to address evolving threats and stay ahead of emerging risks.
- **Use open standards:** Use open standards like OWASP and NIST to ensure consistency and interoperability, promoting transparency and collaboration across the team.
- **Collaborate with communities:** Engage with open source

Table 1: Open source tools that can be used for automating CI/CD in DevSecOps

Category	Objective	Open source tools
Static code analysis (SCA)	Identify vulnerabilities and weaknesses in code	SonarQube, CodeCoverage, CodeHeat
Dynamic application security testing (DAST)	Detect runtime vulnerabilities and weaknesses	OWASP ZAP, Burp Suite, BeEF
Software composition analysis (SCA)	Identify open source component vulnerabilities	Black Duck Hub, Sonatype Nexus, Dependency-Track
Infrastructure as code (IAC)	Secure cloud and infrastructure configurations	Terraform, AWS CloudFormation, Azure ARM
Containerisation	Secure container images and runtime	Docker, Kubernetes, Anchore
Identity and access management (IAM)	Manage access and authentication	LDAP, Active Directory, Okta
Monitoring and logging	Detect and respond to security incidents	ELK Stack (Elasticsearch, Logstash, Kibana), Splunk, Grafana
Compliance and governance	Ensure regulatory compliance and security policies	OpenVAS, Nessus, Compliance Scanner

communities to stay updated on tool developments and best practices, and leverage collective knowledge to enhance your organisation's security practices.

- **Implement security as code:** Store security configurations and policies as code to version and manage them, ensuring that everything is consistent and properly documented.
- **Use infrastructure as code:** Manage infrastructure configurations through code to ensure consistency and security, making it easier to manage complex systems and reduce errors.
- **Prioritise vulnerability management:** Focus on identifying and remediating vulnerabilities early in the development cycle, minimising the risk of security breaches.

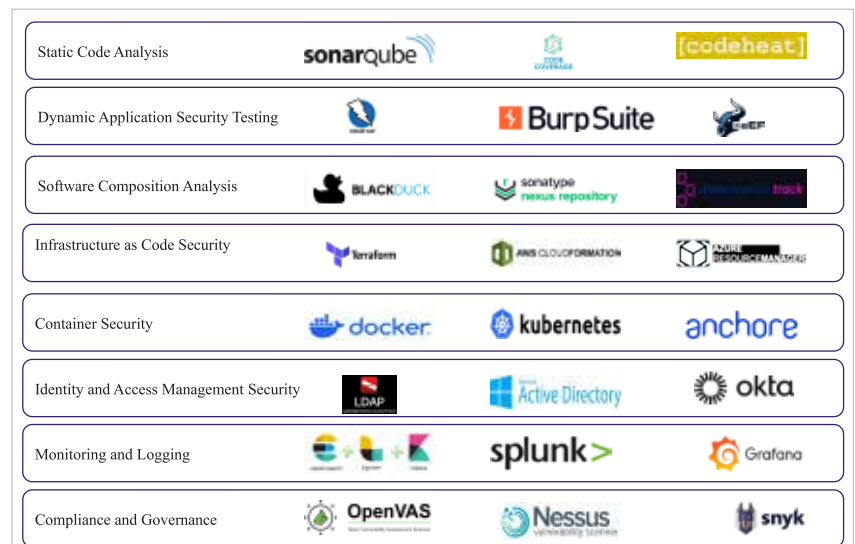


Figure 1: DevSecOps reference architecture